

Guía Metodológica Detallada

Encuesta Nacional sobre Indicadores y Métricas TIBER-EU / TIBER-ES

1. Propósito y alcance

La presente guía describe la metodología para diseñar, administrar y analizar la encuesta nacional sobre el grado de adopción de TIBER-EU/TIBER-ES y el uso de indicadores y métricas de ciberresiliencia en organizaciones financieras y proveedores críticos.

Objetivos principales:

- Medir el nivel de implantación de TIBER-EU/TIBER-ES en España y su alineamiento con DORA/TLPT.
- Evaluar la madurez de las organizaciones en términos de indicadores clave (MTTD, MTTR, cobertura de CIFs, remediación, etc.).
- Identificar buenas prácticas, barreras y oportunidades de mejora para reguladores y entidades.

2. Marco conceptual: enfoque GQM

Se utilizará un enfoque **Goal-Question-Metric (GQM)**:

- Goal (Meta):
Evaluar y mejorar la ciberresiliencia del sector financiero español y su coherencia con el marco TIBER-EU 2025 y TIBER-ES.
- Questions (Preguntas):
 - ¿Hasta qué punto las entidades han definido y cubierto sus funciones críticas (CIFs) en pruebas TIBER?
 - ¿Cómo integran la inteligencia de amenazas (GTL/TTIR) en sus procesos?
 - ¿Qué niveles de detección y respuesta se observan frente a escenarios avanzados?
 - ¿Cómo se cierran las brechas mediante purple teaming y remediación?
- Metrics (Métricas):
 - Porcentaje de CIFs cubiertas.
 - MTTD/MTTR por tipo de escenario.
 - Porcentaje de recomendaciones implementadas.

- Índice Global de Madurez (IGM) compuesto.

Goal (Meta):

Evaluar y mejorar la ciberresiliencia del sector financiero español y su coherencia con el marco TIBER-EU 2025 y TIBER-ES.

Questions (Preguntas):

¿Cómo se cierran las brechas mediante purple teaming y remediación?

Metrics (Métricas):

La encuesta se ha diseñado para que cada bloque de preguntas responda a una o varias preguntas GQM.

3. Población y muestra

3.1. Población objetivo

- Entidades financieras significativas en España:
- Entidades de crédito de importancia sistémica o relevante.
- Entidades aseguradoras/reaseguradoras de mayor tamaño.
- Infraestructuras de mercado financiero.
- Gestoras de activos y otros intermediarios relevantes.
- Proveedores tecnológicos considerados críticos (según DORA o supervisores nacionales).

3.2. Unidad de análisis

La unidad de análisis es la **entidad individual** (no el grupo consolidado), siempre que esté sujeta o potencialmente sujeta a TIBER-ES/TIBER-EU o a pruebas TLPT equivalentes.

En grupos multinacionales, se recomienda una respuesta por entidad significativa en España.

3.3. Selección muestral

- Muestra censal para las entidades sujetas a TIBER-ES o consideradas sistémicas.
- Muestra estratificada para el resto, con estratos por tamaño y subsector.
- Posibilidad de extender el ejercicio a entidades voluntarias (“early adopters”).

4. Roles y responsabilidades

- Equipo coordinador (p. ej. autoridad nacional o consorcio sectorial):
 - Diseñar la versión final de la encuesta.
 - Gestionar la plataforma de recogida de respuestas.
 - Realizar el análisis estadístico agregado.
- Punto de contacto en cada entidad (CISO u homólogo):
 - Coordinar la cumplimentación interna de la encuesta.
 - Recabar información de otras áreas (riesgo, continuidad, negocio, etc.).
 - Validar las respuestas antes de su envío.
- Comité asesor técnico:
 - Revisar la coherencia de la encuesta con TIBER-EU/TIBER-ES y DORA.
 - Proponer mejoras en indicadores y metodología para futuras iteraciones.

Realizar el análisis estadístico agregado.

Punto de contacto en cada entidad (CISO u homólogo):

Validar las respuestas antes de su envío.

Comité asesor técnico:

5. Diseño del cuestionario

5.1. Estructura por bloques

El cuestionario se organiza en los bloques descritos en el Modelo de Encuesta:

1. Contexto de la entidad.
2. Gobernanza y CIFs.
3. Inteligencia de amenazas.
4. Red Team y escenarios.
5. Detección y respuesta.
6. Purple teaming, remediación y aprendizaje.
7. Relación con supervisores y terceros.
8. Indicadores internos y ROI.

5.2. Tipos de preguntas

- Preguntas cerradas de selección única o múltiple.
- Escalas de Likert 0–5 para madurez.
- Preguntas abiertas breves para recoger matices cualitativos.

Todas las preguntas están redactadas para minimizar juicios de valor explícitos, aunque se admite un leve tono irónico para fomentar respuestas honestas y reflexivas.

5.3. Validación y prueba piloto

- Se recomienda una prueba piloto con 5–10 entidades representativas.
- Dar feedback estructurado sobre:
- Claridad de la redacción.
- Tiempo de cumplimentación.
- Disponibilidad real de los datos solicitados.
- Ajustar la encuesta tras el piloto antes del despliegue masivo.

6. Administración de la encuesta

6.1. Canal y formato

- Preferentemente, una plataforma online segura (HTTPS, autenticación robusta).
- Posibilidad de versión offline en formato .xlsx o .docx si fuese necesario.
- Cada entidad debe tener un identificador interno para los análisis agregados.

6.2. Plazos

- Plazo de cumplimentación recomendado: 4–6 semanas.
- Recordatorios periódicos (al menos dos) a puntos de contacto.
- Posible extensión del plazo en función del nivel de respuesta.

6.3. Confidencialidad y uso de los datos

- Fijar contractualmente el uso de los datos:
- Análisis agregado y anonimizado.
- Prohibición de publicar resultados identificables sin consentimiento.
- Explicar claramente que el objetivo es la mejora colectiva, no la clasificación pública de “ganadores” y “perdedores”.

7. Cálculo de indicadores y del Índice Global de Madurez (IGM)

7.1. Dimensiones del IGM

El IGM se estructura en al menos cinco dimensiones:

9. Gobernanza y CIFs (GOV).
10. Inteligencia de amenazas (TI).
11. Capacidades de Red Team y escenarios (RT).
12. Detección y respuesta (BLUE).
13. Purple teaming, remediación y aprendizaje (PRP).

Cada dimensión se alimenta de un subconjunto de preguntas de la encuesta.

7.2. Escalado y normalización

- Las preguntas en escala 0–5 se utilizan directamente.
- Las preguntas categóricas se asignan a valores 0–5 según criterios predefinidos (descritos en la Plantilla Excel de IGM y ROI).
- Las preguntas cuantitativas (porcentajes, MTDD/MTTR) se transforman en puntuaciones mediante tramos:

- Ejemplo MTDD:

< 1 h → 5
1–24 h → 4
1–7 días → 3

7 días → 2

No detectado → 0

Las preguntas cuantitativas (porcentajes, MTDD/MTTR) se transforman en puntuaciones mediante tramos:

Ejemplo MTDD:

- < 1 h → 5
- 1–24 h → 4
- 1–7 días → 3
-

7 días → 2

- No detectado → 0

7 días → 2

7.3. Agregación

Para cada entidad:

- Calcular la media (o mediana) de las puntuaciones normalizadas de cada dimensión.
- Calcular el IGM total como media ponderada de dimensiones:

$$\begin{bmatrix} \\ \text{IGM} = \sum_{d} w_d \cdot \text{score}_d \\ \end{bmatrix}$$

Donde (w_d) son los pesos de cada dimensión (por defecto, iguales).

7.4. Interpretación

- $\text{IGM} < 2$: zona de riesgo crítico (baja madurez).
- $2 \leq \text{IGM} < 3$: madurez básica, con brechas relevantes.
- $3 \leq \text{IGM} < 4$: madurez razonable, TIBER aprovechado.
- $4 \leq \text{IGM} \leq 5$: alta madurez, referente sectorial.

Estas bandas son orientativas y pueden adaptarse.

8. Estimación de ROI

La plantilla Excel propone:

- Estimar costes directos e indirectos de un ejercicio TIBER (contratación TI/RTT, horas internas, etc.).
- Estimar beneficios esperados en términos de:
- Reducción de probabilidad de incidentes graves.
- Reducción del impacto esperado (económico, reputacional, regulatorio).
- Cumplimiento de DORA/TLPT (evitar sanciones, restricciones, etc.).

El ROI se calcula como:

$$\left[\text{ROI} = \frac{\text{Beneficios_esperados} - \text{Costes}}{\text{Costes}} \right]$$

La guía recomienda no obsesionarse con la exactitud milimétrica, sino con la coherencia interna y la comparabilidad entre entidades.

9. Análisis y reporte

9.1. Análisis cuantitativo

- Distribuciones de IGM y de cada dimensión.
- Comparaciones por subsector, tamaño, tipo de entidad.
- Correlaciones exploratorias (por ejemplo, entre uso de TTIR y MTTD).

9.2. Análisis cualitativo

- Categorización de respuestas abiertas en temas recurrentes.
- Identificación de casos de buenas prácticas destacables.

9.3. Reporte

- Uso de la Plantilla de Reporte Ejecutivo para presentación a:
- Autoridades.
- Asociaciones sectoriales.
- Foros de CISOs.

10. Revisión y actualización

Dado que TIBER-EU y DORA pueden actualizarse, se recomienda:

- Revisar la encuesta y esta guía al menos cada dos años.
- Ajustar las preguntas y mapeos normativos para incorporar cambios regulatorios y de buenas prácticas.

Fin de la Guía Metodológica Detallada.